

Internal Security Audit Report

Botium Toys — Controls & Compliance Checklist

Conducted by: Krishna Chandra GS | Framework: NIST CSF | Date: 2025

Audit Scope & Goals

Scope: The entire security program at Botium Toys — all assets, internal processes, and procedures related to controls implementation and compliance best practices.

Goal: Assess existing assets and determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture. Risk score: **8/10 (High)**.

Controls Assessment Checklist

Does Botium Toys currently have this control in place?

Yes	No	Control
	NO	Least Privilege
	NO	Disaster Recovery Plans
	NO	Password Policies (nominal — below minimum requirements)
	NO	Separation of Duties
YES		Firewall
	NO	Intrusion Detection System (IDS)
	NO	Backups
YES		Antivirus Software
	NO	Manual Monitoring / Maintenance for Legacy Systems (no schedule)
	NO	Encryption
	NO	Password Management System
YES		Locks (offices, storefront, warehouse)
YES		CCTV Surveillance
YES		Fire Detection / Prevention Systems

Compliance Checklist

Payment Card Industry Data Security Standard (PCI DSS)

Does Botium Toys currently adhere to this compliance best practice?

Yes	No	Best Practice
	NO	Only authorized users have access to customers' credit card information
	NO	Credit card information is stored, accepted, processed, and transmitted in a secure environment
	NO	Data encryption procedures implemented for credit card transaction touchpoints
	NO	Secure password management policies adopted

General Data Protection Regulation (GDPR)

Yes	No	Best Practice
	NO	E.U. customers' data is kept private and secured
YES		Plan in place to notify E.U. customers within 72 hours of a breach
	NO	Data is properly classified and inventoried
YES		Privacy policies, procedures, and processes enforced and documented

System and Organizations Controls (SOC Type 1 & 2)

Yes	No	Best Practice
	NO	User access policies are established
	NO	Sensitive data (PII/SPII) is confidential and private
YES		Data integrity ensures data is consistent, complete, accurate, and validated
YES		Data is available to individuals authorized to access it

Recommendations

- **CRITICAL — Implement Least Privilege & Separation of Duties:** All employees currently have access to cardholder data and PII/SPII. This is the most urgent gap and directly violates PCI DSS and GDPR requirements.
- **CRITICAL — Enable Encryption:** Credit card data stored in the internal database is completely unencrypted. This exposes Botium Toys to severe PCI DSS fines and data breach liability.
- **HIGH — Deploy an IDS:** No intrusion detection system is in place, meaning threats can persist on the network undetected. An IDS should be prioritised immediately after access controls.
- **HIGH — Create Disaster Recovery Plans & Backups:** A single incident could cause complete and unrecoverable business disruption. Implement automated backups and a documented recovery plan.
- **MEDIUM — Implement a Password Management System:** Enforce the existing password policy with a centralised tool to reduce both security risk and IT helpdesk burden.
- **MEDIUM — Formalise Legacy System Monitoring:** Establish a regular schedule with clear intervention methods for legacy system maintenance to reduce unmanaged risk.

Compliance summary: Botium Toys is 0/4 on PCI DSS, 2/4 on GDPR, and 2/4 on SOC. Addressing access controls and encryption will have the highest combined impact across all three frameworks.